AS/NZS 4360:2004

Australian/New Zealand Standard®

RISK MANAGEMENT



This is a free 8 page sample. Access the full version online.

STANDARDS AUSTRALIA

STANDARDS NEW ZEALAND

Gestión de riesgos
AS / NZS 4360: 2004

Esta Norma Conjunta Australia / Nueva Zelanda fue preparada por el Comité Técnico Conjunto OB-007, Gestión de Riesgos. Fue aprobado en nombre del Consejo de Normas de Australia el 21 de julio de 2004 y en nombre del Consejo de Normas de Nueva Zelandia el 20 de agosto de 2004.

Los siguientes están representados en el Comité OB-007:

Sociedad Australiana de Computación

Servicio de Aduanas de Australia

Australia Instituto de Seguros y Finanzas de Nueva Zelanda

CSIRO (Organización de Investigación Científica e Industrial de la Commonwealth)

Departamento de Defensa (Australia)

Departamento de Finanzas y Administración

Gestión de emergencias en Australia

Autoridad de gestión de riesgos ambientales (Nueva Zelandia)

Instituto de Contadores Públicos (Australia)

Institución de Ingenieros Australia

Institución de Ingenieros Profesionales Nueva Zelanda

Gobierno Local Nueva Zelanda

Massey University (Nueva Zelanda)

Consejo de Minerales de Australia

Ministerio de Agricultura y Silvicultura (Nueva Zelandia)

Ministerio de Desarrollo Económico (Nueva Zelandia)

Fondo gestionado por el Tesoro de Nueva Gales del Sur

Sociedad de Nueva Zelanda para la Gestión de Riesgos

Institución de Gestión de Riesgos de Australasia

Instituto de Seguridad de Australia

Instituto de Valores de Australia

Universidad de Nueva Gales del Sur

Autoridad Victorian WorkCover

Asociación de Servicios del Agua de Australia

Esta Norma fue emitida en forma de borrador para comentarios como DR 03360.

Originado como AS / NZS 4360: 1995.
Segunda edición 1999.
Tercera edición 2004

Mantener estándares actualizados

Las normas son documentos vivos que reflejan el progreso de la ciencia, la tecnología y los sistemas. Para mantener su moneda, todos los Estándares son revisados periódicamente, y se editan nuevas ediciones. Entre ediciones, pueden emitirse enmiendas. Las normas también pueden ser retiradas. Es importante que los lectores se aseguren de que están usando una Norma vigente, la cual debe incluir cualquier enmienda que pueda haber sido publicada desde que se compró la Norma. Puede encontrar información detallada sobre las normas conjuntas de Australia y Nueva Zelanda visitando la página Web de Standards en www.standards.com.au o el sitio web de Standards New Zealand en www.standards.co.nz y buscando la norma pertinente en el sitio web on- Catálogo de líneas. Alternativamente, ambas organizaciones publican un catálogo impreso anual con todos los detalles de todas las Normas vigentes. Para los listados más frecuentes o la notificación de revisiones, enmiendas y retiros, Standards Australia y Standards New Zealand ofrecen una serie de opciones de actualización. Para obtener información sobre estos servicios, los usuarios deben ponerse en contacto con su respectiva organización nacional de estándares. También damos la bienvenida a sugerencias para mejorar nuestras Normas, y alentamos especialmente a los lectores a notificarnos inmediatamente cualquier inexactitud o ambigüedad aparente. Por favor, envíe sus comentarios al Director Ejecutivo de Standards Australia International o Standards New Zealand en la dirección que se muestra en la contraportada.

ISBN 0 7337 5904 1

© Standards Australia / Standards New Zealand
Todos los derechos reservados. Ninguna parte de este trabajo puede ser reproducida o copiada de ninguna forma ni por ningún medio, electrónico o mecánico, incluyendo fotocopia, sin el permiso escrito del editor. Publicado conjuntamente por Standards Australia International Ltd, GPO Box 5420, Sydney, NSW 2001 y Standards New Zealand, Private Bag 2439, Wellington 6020.

Prefacio

Esta Norma fue preparada por el Comité de Normas Conjuntas Australia / Normas Nueva Zelanda OB-007, Gestión de Riesgos como una revisión de AS / NZS 4360: 1999, Gestión de riesgos. Proporciona un marco genérico para establecer el contexto, identificar, analizar, evaluar, tratar, monitorear y comunicar el riesgo. Esta Norma revisada incorpora los conocimientos adquiridos a través de la aplicación de la edición de 1999 y el pensamiento actual sobre la gestión de riesgos. Algunos de los cambios de la edición de 1999 incluyen-

- mayor énfasis en la importancia de incorporar las prácticas de gestión de riesgos en la cultura y los procesos de la organización;

- un mayor énfasis en la gestión de las ganancias potenciales, así como en las pérdidas potenciales; y

- Movimiento y expansión de ejemplos indicativos en un nuevo manual.

HB 436, Directrices para la Gestión de Riesgos-Acompañamiento a la AS / NZS 4360: 2004 contiene orientaciones específicas sobre la implementación de la Norma. Los dos documentos están destinados a ser utilizados juntos.

Además, Standards Australia y Standards New Zealand han publicado una serie de manuales sobre la manera en que el proceso de gestión de riesgos puede aplicarse en una variedad de sectores y una gama de áreas temáticas.

Contenido

1 Alcance y generalidad 1

1.1 Alcance y aplicación 1

1.2 Objetivo 1

1.3 Definiciones 2

1.4 Terminología y traducción.....6

1.5 Documentos de referencia 6

2 Visión general del proceso de gestión de riesgos 7

2.1 Generalidades 7

2.2 Principales elementos 7

3 Proceso de gestión de riesgos 11

3.1 Comunicar y consultar.....11

3.2 Establecer el contexto 12

3.3 Identificar los riesgos 16

3.4 Analizar los riesgos 16

3.5 Evaluar los riesgos 19

3.6 Tratamiento de los riesgos 20

3.7 Monitorear y revisar 22

3.8 Registrar el proceso de gestión de riesgos..23

4 Establecer una gestión eficaz de los riesgos

4.1 Propósito 25

4.2 Evaluar las prácticas y necesidades existentes.25

4.3 Planificación de la gestión de riesgos.....26

Prefacio

La gestión de riesgos implica gestionar para lograr un equilibrio adecuado entre la realización de oportunidades de ganancias y minimizar las pérdidas. Forma parte integrante de las buenas prácticas de gestión y es un elemento esencial del buen gobierno corporativo. Se trata de un proceso iterativo que consiste en pasos que, cuando se realizan en secuencia, permiten una mejora continua en la toma de decisiones y facilitan la mejora continua del rendimiento.

La gestión del riesgo consiste en establecer una infraestructura y una cultura adecuadas y aplicar un método lógico y sistemático para establecer el contexto, identificar, analizar, evaluar, tratar, supervisar y comunicar los riesgos asociados con cualquier actividad, función o proceso de manera que las organizaciones puedan minimizar Pérdidas y maximizar ganancias. Para ser más efectivo, la gestión del riesgo debe convertirse en parte de la cultura de una organización. Debe ser incorporado en la filosofía de la organización, las prácticas y los procesos de negocio en lugar de ser visto o practicado como una actividad independiente. Cuando esto se logra, todos en la organización se involucran en la gestión del riesgo.

Aunque el concepto de riesgo se interpreta a menudo en términos de peligros o impactos negativos, esta Norma se refiere al riesgo como exposición a las consecuencias de la incertidumbre o posibles desviaciones de lo planeado o esperado. El proceso descrito aquí se aplica a la administración de ganancias potenciales y pérdidas potenciales.

Las organizaciones que gestionan el riesgo de manera eficaz y eficiente tienen más probabilidades de alcanzar sus objetivos y hacerlo a un menor costo general.

1 Alcance y generalidad

1.1 Alcance y aplicación

Esta Norma proporciona una guía genérica para la gestión del riesgo. Esta Norma puede aplicarse a una amplia gama de actividades, decisiones u operaciones de cualquier empresa, grupo o individuo público, privado o comunitario. Si bien la Norma tiene una aplicabilidad muy amplia, los procesos de gestión de

riesgos son comúnmente aplicados por organizaciones o grupos y así, por conveniencia, el término "organización" se ha utilizado a lo largo de esta Norma.

Esta Norma especifica los elementos del proceso de gestión de riesgos, pero no es el propósito de esta Norma reforzar la uniformidad de los sistemas de gestión de riesgos. Es genérico e independiente de cualquier industria o sector económico específico. El diseño y la implementación del sistema de gestión de riesgos estarán influenciados por las diversas necesidades de una organización, sus objetivos particulares, sus productos y servicios, y los procesos y prácticas concretas empleadas.

Esta Norma debe aplicarse en todas las etapas de la vida de una actividad, función, proyecto, producto o activo. El beneficio máximo se obtiene generalmente aplicando el proceso de gestión de riesgos desde el principio. A menudo se realizan diversos estudios discretos en diferentes momentos y desde perspectivas estratégicas y operativas.

El proceso descrito aquí se aplica a la administración de ganancias potenciales y pérdidas potenciales.

1.2 Objetivo

El objetivo de esta Norma es proporcionar una guía que permita a las empresas, grupos e individuos públicos, privados o comunitarios lograr -

• una base más confiable y rigurosa para la toma de decisiones y la planificación;

• mejor identificación de oportunidades y amenazas;

• obtener valor de la incertidumbre y la variabilidad;

• gestión pro-activa en lugar de re-activa;

• asignación y utilización más eficaces de los recursos;

• mejora de la gestión de incidentes y reducción de pérdidas y del coste del riesgo, incluidas las primas de seguros comerciales;

• mejora de la confianza y la confianza de las partes interesadas;

• mejora del cumplimiento de la legislación pertinente; y

• un mejor gobierno corporativo.

1.3 Definiciones

A los efectos de esta Norma, se aplican las siguientes definiciones.

1.3.1 Consecuencia

Resultado o impacto de un evento (1.3.4)

NOTA 1: Puede haber más de una consecuencia de un evento.

NOTA 2: Las consecuencias pueden variar de positivo a negativo.

NOTA 3: Las consecuencias pueden expresarse cualitativa o cuantitativamente.

NOTA 4: Se consideran las consecuencias en relación con el logro de los objetivos.

1.3.2 Control

Un proceso, una política, un dispositivo, una práctica u otra acción existente que actúe para minimizar el riesgo negativo o mejorar las oportunidades positivas NOTA: La palabra "control" también puede aplicarse a un proceso diseñado para proporcionar una seguridad razonable respecto al logro de los objetivos.

1.3.3 Evaluación del control

Revisión sistemática de los procesos para asegurar que los controles (1.3.2) siguen siendo efectivos y apropiados NOTA: La revisión periódica de los controles por parte de la gerencia de línea se denomina a menudo "autoevaluación del control".

1.3.4 Evento

Ocurrencia de un conjunto particular de circunstancias

NOTA 1: El evento puede ser seguro o incierto.

NOTA 2: El evento puede ser una sola ocurrencia o una serie de ocurrencias.

(ISO / IEC Guía 73, en parte)

1.3.5 Frecuencia

Una medida del número de ocurrencias por unidad de tiempo.

1.3.6 Peligro

Una fuente de daño potencial

(ISO / IEC Guía 51, en parte)

1.3.7 Probabilidad

Utilizado como una descripción general de probabilidad o frecuencia

NOTA: Se puede expresar cualitativamente o cuantitativamente.

1.3.8 Pérdida

Cualquier consecuencia negativa (1.3.1) o efecto adverso, financiero o de otro tipo

1.3.9 Monitor

Para verificar, supervisar, observar críticamente o medir el progreso de una actividad, acción o sistema de forma regular con el fin de identificar el cambio desde el nivel de rendimiento requerido o esperado

1.3.10 Organización

Grupo de personas e instalaciones con un arreglo de responsabilidades, autoridades y relaciones

EJEMPLO: Incluye empresa, corporación, firma, empresa, institución, caridad, comerciante individual, asociación, o partes o combinación de los mismos.

NOTA 1: La disposición es generalmente ordenada.

NOTA 2: Una organización puede ser pública o privada.

NOTA 3: Esta definición es válida para los propósitos de las normas del sistema de gestión de la calidad. El término "organización" se define de manera diferente en la Guía ISO / IEC 2.

(AS / NZS ISO 9000)

1.3.11 Probabilidad

Una medida de la probabilidad de ocurrencia expresada como un número entre 0 y 1

NOTA 1: La Guía ISO / IEC 73 define la probabilidad como la 'medida en la cual un evento (1.3.4) es probable que ocurra'

NOTA 2: ISO 3534-1: 1993, definición 1.1, da la definición matemática de probabilidad como 'un número real en la escala 0 a 1 unido a un evento aleatorio'. Va a notar que la probabilidad 'puede estar relacionada con una frecuencia relativa de ocurrencia a largo plazo o con un grado de creencia de que ocurrirá un evento. Para un alto grado de creencia, la probabilidad está cerca de 1. '

NOTA 3: "Frecuencia" o "probabilidad" en lugar de "probabilidad" pueden ser utilizados para describir el riesgo (1.3.13).

1.3.12 Residual

Riesgo de (1.3.13) que queda después de la aplicación del tratamiento del riesgo (1.3.26)

NOTA: Consulte la Guía 51 ISO / IEC para aplicaciones de seguridad.

1.3.13 Riesgo

La posibilidad de que algo ocurra que tenga un impacto en los objetivos

NOTA 1: A menudo se especifica un riesgo en términos de un evento o circunstancia y las consecuencias que pueden derivarse de él.

NOTA 2: El riesgo se mide en términos de una combinación de las consecuencias de un suceso (1.3.4) y su probabilidad (1.3.7).

NOTA 3: El riesgo puede tener un impacto positivo o negativo.

NOTA 4: Véase la Guía ISO / CEI 51 para cuestiones relacionadas con la seguridad.

1.3.14 Análisis de riesgos

Proceso sistemático para entender la naturaleza de y para deducir el nivel de riesgo

NOTA 1: Proporciona la base para la evaluación del riesgo y las decisiones sobre el tratamiento del riesgo.

NOTA 2: Véase la Guía ISO / CEI 51 para el análisis de riesgos en el contexto de la seguridad.

1.3.15 Evaluación del riesgo

El proceso general de identificación de riesgos (1.3.19), el análisis de riesgos (1.3.14) y la evaluación de riesgos (1.3.18), véase la figura 3.1

1.3.16 Evitar el riesgo

Una decisión de no involucrarse o retirarse de una situación de riesgo (1.3.13)

1.3.17 Criterios de riesgo

Términos de referencia mediante los cuales se evalúa la importancia del riesgo (1.3.13)

NOTA: Los criterios de riesgo pueden incluir los costos y beneficios asociados, los requisitos legales y estatutarios, los aspectos socioeconómicos y ambientales, las preocupaciones de las partes interesadas (1.3.27), las prioridades y otros aportes a la evaluación.

1.3.18 Evaluación del riesgo

Proceso de comparación del nivel de riesgo (1.3.13) con los criterios de riesgo (1.3.17)

NOTA 1: La evaluación del riesgo ayuda a tomar decisiones sobre el tratamiento del riesgo.

NOTA 2: Véase la Guía ISO / IEC 51 para la evaluación de riesgos en el contexto de la seguridad.

1.3.19 Identificación de riesgos

El proceso de determinar qué, dónde, cuándo, por qué y cómo podría suceder algo

1.3.20 Gestión del riesgo

La cultura, los procesos y las estructuras que se dirigen hacia la realización de oportunidades potenciales, mientras que la gestión de los efectos adversos

1.3.21 Proceso de gestión de riesgos

La aplicación sistemática de políticas, procedimientos y prácticas de gestión a las tareas de comunicación, establecimiento del contexto, identificación, análisis, evaluación, tratamiento, seguimiento y revisión del riesgo (1.3.13)

1.3.22 Marco de gestión de riesgos

Conjunto de elementos del sistema de gestión de una organización (1.3.10) relacionado con la gestión del riesgo (1.3.13)

NOTA 1: Los elementos del sistema de gestión pueden incluir la planificación estratégica, la toma de decisiones y otras estrategias, procesos y prácticas para hacer frente al riesgo.

NOTA 2: La cultura de una organización se refleja en su sistema de gestión de riesgos.

1.3.23 Reducción del riesgo

Acciones tomadas para disminuir la probabilidad (1.3.7), consecuencias negativas (1.3.1), o ambas, asociadas con un riesgo (1.3.13)

1.3.24 Retención de riesgos

Aceptación de la carga de la pérdida, o beneficio de la ganancia, de un riesgo particular (1.3.13)

NOTA 1: La retención de riesgos incluye la aceptación de riesgos que no han sido identificados.

NOTA 2: El nivel de riesgo retenido puede depender de criterios de riesgo (1.3.17).

(ISO / IEC Guía 73, en parte)

1.3.25 Compartición del riesgo

Compartir con otra parte la carga de la pérdida, o beneficiarse de la ganancia de un riesgo particular (1.3.13)

NOTA 1: Los requisitos legales o estatutarios pueden limitar, prohibir o ordenar el reparto de algunos riesgos.

NOTA 2: El reparto del riesgo puede realizarse a través de seguros u otros acuerdos.

NOTA 3: El riesgo compartido puede crear nuevos riesgos o modificar un riesgo existente.

1.3.26 Tratamiento de riesgos

Proceso de selección e implementación de medidas para modificar el riesgo (1.3.13)

NOTA 1: El término "tratamiento del riesgo" se utiliza a veces para las propias medidas.

NOTA 2: Las medidas de tratamiento de riesgos pueden incluir evitar, modificar, compartir o retener el riesgo.

(ISO / IEC Guía 73, en parte)

1.3.27 Partes interesadas

Aquellas personas y organizaciones (1.3.10) que puedan afectar, verse afectadas o considerarse afectadas por una decisión, actividad o riesgo.

NOTA: El término "partes interesadas" también puede incluir "partes interesadas" tal como se definen en la norma ISO / NZS ISO 14050 y AS / NZS ISO 14004.

(Basado en la Guía ISO / IEC 73)

1.4 Terminología y traducción

La versión en inglés de esta Norma utiliza la palabra "probabilidad" para referirse a la posibilidad de que algo suceda, ya sea definido, medido o estimado objetiva o subjetivamente, o en términos de descriptores generales (como raros, improbables, probables, casi ciertos), Frecuencias o probabilidades (matemáticas).

ISO / IEC Guía 73 utiliza la palabra 'probabilidad', en este sentido general, para evitar problemas de traducción de 'probabilidad' en algunos idiomas no ingleses que no tienen equivalente directo. Debido a que la "probabilidad" es a menudo interpretada de manera más formal en inglés como término matemático, la "verosimilitud" se utiliza a lo largo de esta Norma, con la intención de que tenga la misma

interpretación amplia que la "probabilidad" definida en ISO / IEC Guía 73.

1.5 Documentos de referencia

En esta Norma se hace referencia a los siguientes documentos:

Guía ISO / IEC 51 Aspectos de seguridad-Directrices para su inclusión en las normas

ISO / IEC Guía 73 Gestión del riesgo-Vocabulario-Directrices para el uso en normas

ISO 3534-1 Estadísticas; Vocabulario y símbolos; Parte 1: Probabilidad y términos estadísticos generales

AS / NZS ISO 9000 Sistemas de gestión de la calidad - Fundamentos y vocabulario

AS / NZS ISO 14004 Sistemas de gestión medioambiental- Directrices generales sobre principios, sistemas y técnicas de apoyo

AS ISO 14050 Gestión ambiental-Vocabulario

AS ISO 15489 Gestión de registros

HB 18.2 Estandarización y actividades relacionadas - Vocabulario general

HB 436 Directrices de Gestión de Riesgos - Acompañamiento a AS / NZS 4360: 2004

2 Visión general del proceso de gestión de riesgos

2.1 General

En esta sección se ofrece un breve resumen del proceso de gestión de riesgos. Cada paso del proceso de gestión de riesgos se discute con mayor detalle en la Sección 3.

La gestión del riesgo es una parte integral de la buena gestión. Se trata de un proceso iterativo de mejora continua que se inserta mejor en las prácticas existentes o en los procesos empresariales.

2.2 Elementos principales

Los principales elementos del proceso de gestión de riesgos, como se muestra en la Figura 2.1, son los siguientes:

(a) Comunicarse y consultar

Comunicar y consultar con las partes interesadas internas y externas, según proceda, en cada etapa del proceso de gestión de riesgos y en relación con el proceso en su conjunto.

(b) Establecer el contexto

Establecer el contexto externo, interno y de gestión de riesgos en el que se llevará a cabo el resto del proceso. Deberían establecerse criterios que permitan evaluar el riesgo y definir la estructura del análisis.

(c) Identificar los riesgos

Identificar dónde, cuándo, por qué y cómo los eventos podrían prevenir, degradar, retrasar o mejorar el logro de los objetivos.

(d) Analizar los riesgos

Identificar y evaluar los controles existentes. Determinar las consecuencias y la probabilidad y, por lo tanto, el nivel de riesgo. Este análisis debe considerar la gama de posibles consecuencias y cómo estas podrían ocurrir.

(e) Evaluar los riesgos

Compare los niveles estimados de riesgo con los criterios preestablecidos y considere el equilibrio entre los beneficios potenciales y los resultados adversos. Esto permite tomar decisiones sobre el alcance y la naturaleza de los tratamientos requeridos y sobre las prioridades.

(f) Tratar los riesgos

Elaborar e implementar estrategias y planes de acción específicos de costo efectivo para aumentar los beneficios potenciales y reducir los costos potenciales.

(g) Monitorear y revisar

Es necesario vigilar la efectividad de todas las etapas del proceso de gestión de riesgos. Esto es importante para la mejora continua.

Es necesario controlar los riesgos y la eficacia de las medidas de tratamiento para garantizar que las circunstancias cambiantes no alteren las prioridades.

La gestión de riesgos se puede aplicar en muchos niveles en una organización. Se puede aplicar a nivel estratégico ya nivel táctico y operacional. Puede aplicarse a proyectos específicos, para ayudar con decisiones específicas o para manejar áreas de riesgo específicas reconocidas.

Para cada etapa del proceso deben mantenerse registros para permitir que las decisiones sean entendidas como parte de un proceso de mejora continua.

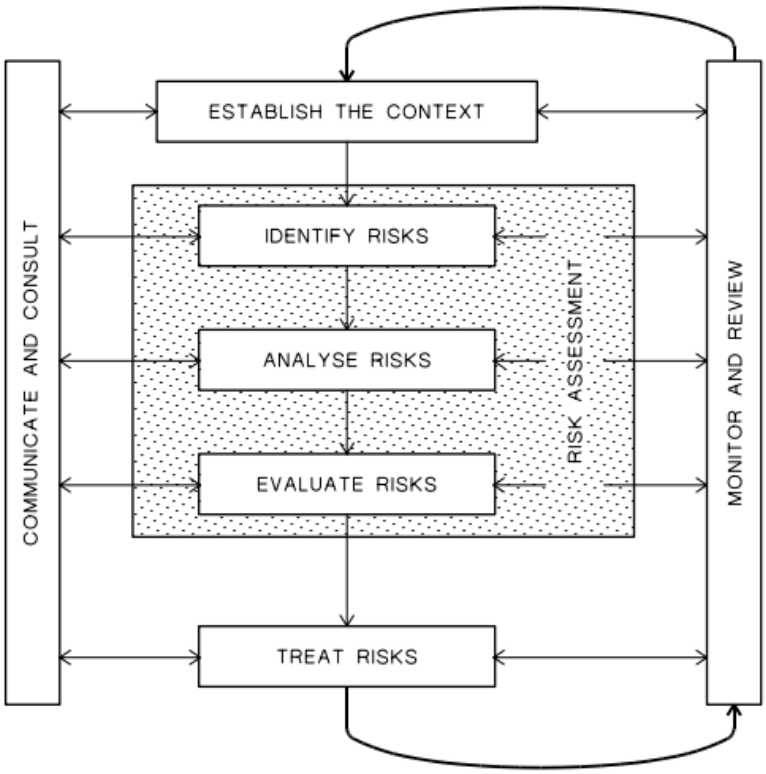


FIGURE 2.1 RISK MANAGEMENT PROCESS – OVERVIEW

3 Proceso de gestión de riesgos

Los detalles del proceso de gestión de riesgos se muestran en la Figura 3.1.

3.1 Comunicar y consultar

La comunicación y la consulta son consideraciones importantes en cada paso del proceso de gestión de riesgos. Deben implicar un diálogo con las partes interesadas con esfuerzos centrados en la consulta en lugar de un flujo unidireccional de información del tomador de decisiones a otras partes interesadas.

Es importante desarrollar un plan de comunicación para las partes interesadas tanto internas como externas en la primera etapa del proceso. Este plan debe abordar

las cuestiones relacionadas tanto con el riesgo en sí como con el proceso para gestionarlo.

Una comunicación interna y externa efectiva es importante para asegurar que los responsables de la implementación de la gestión de riesgos y aquellos con intereses creados entiendan la base sobre la cual se toman las decisiones y por qué se requieren acciones particulares.

Es probable que las partes interesadas hagan juicios sobre el riesgo basándose en sus percepciones. Estos pueden variar debido a las diferencias en valores, necesidades, suposiciones, conceptos y preocupaciones que se relacionan con los riesgos o las cuestiones en discusión. Dado que las opiniones de las partes interesadas pueden tener un impacto significativo en las decisiones tomadas, es importante que sus percepciones del riesgo sean identificadas y registradas e integradas en el proceso de toma de decisiones.

Un enfoque de equipo consultivo es útil para ayudar a definir el contexto apropiadamente, para ayudar a asegurar que los riesgos se identifican de manera efectiva, para reunir diferentes áreas de experiencia en el análisis de riesgos, para asegurar que diferentes puntos de vista se consideren apropiadamente en la evaluación de riesgos y para una adecuada gestión del cambio durante el tratamiento del riesgo . La participación también permite la "apropiación" del riesgo por parte de los administradores y la participación de las partes interesadas. Les permite apreciar los beneficios de controles específicos y la necesidad de respaldar y apoyar un plan de tratamiento.

Los registros de comunicación y consulta dependerán de factores tales como la escala y la sensibilidad de la actividad.

3.2 Establecer el contexto

3.2.1 Generalidades

Establecer el contexto define los parámetros básicos dentro de los cuales se deben gestionar los riesgos y establece el ámbito para el resto del proceso de gestión de riesgos. El contexto incluye el entorno externo e interno de la organización y el propósito de la actividad de gestión de riesgos. Esto también incluye la consideración de la interfaz entre los entornos externo e interno.

Esto es importante para asegurar que los objetivos definidos para el proceso de gestión de riesgos tengan en cuenta el entorno organizativo y externo.

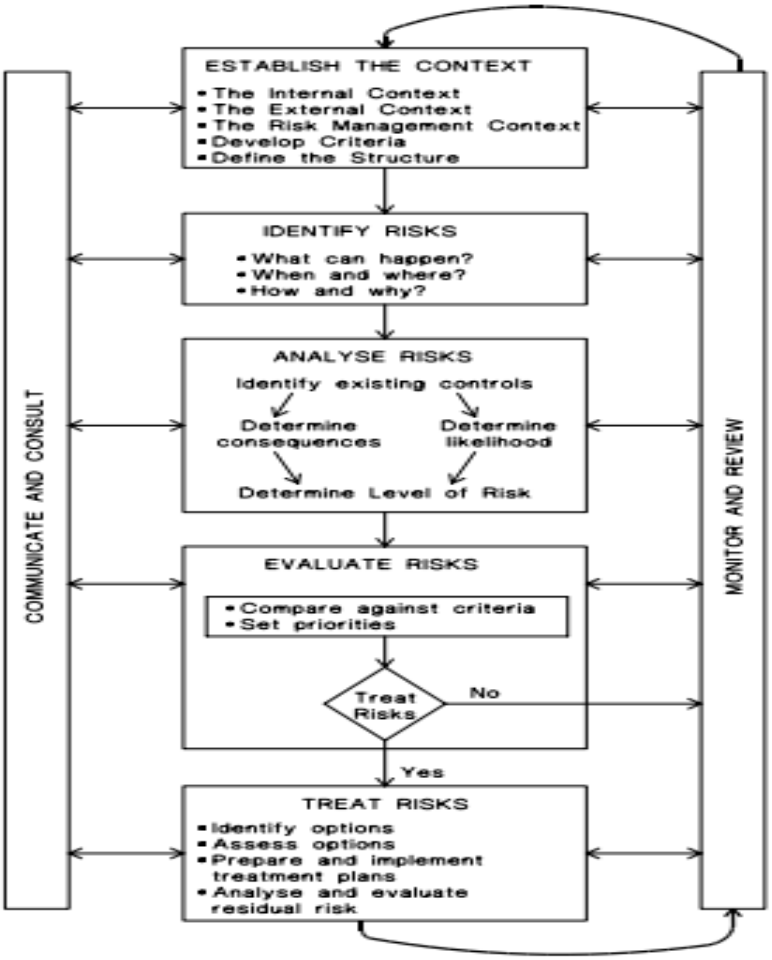


Figura 3.1 Proceso de Gestión de Riesgos-En detalle

3.2.2 Establecer el contexto externo

Este paso define el entorno externo en el que opera la organización.

También define la relación entre la organización y su entorno externo. Esto puede, por ejemplo, incluir:

• el entorno empresarial, social, regulatorio, cultural, competitivo, financiero y político;

• fortalezas, debilidades, oportunidades y amenazas de la organización;

• interesados externos; y

• los principales impulsores del negocio.

Es particularmente importante tener en cuenta las percepciones y los valores de las partes interesadas externas y establecer políticas de comunicación con estas partes.

Establecer el contexto externo es importante para asegurar que las partes interesadas y sus objetivos se consideran al desarrollar criterios de gestión de riesgos y que las amenazas y oportunidades generadas externamente se tienen debidamente en cuenta.

3.2.3 Establecer el contexto interno

Antes de iniciar una actividad de gestión de riesgos, a cualquier nivel, es necesario entender la organización. Las áreas clave incluyen:

• cultura;

• las partes interesadas internas;

• estructura;

• capacidades en términos de recursos como personas, sistemas, procesos, capital; y

• las metas y los objetivos y las estrategias que existen para lograrlos. Establecer el contexto interno es importante porque:

• la gestión de riesgos se lleva a cabo en el contexto de las metas y objetivos de la organización;

• el mayor riesgo para la mayoría de las organizaciones es que no alcancen sus objetivos estratégicos, empresariales o de proyecto, o que se perciba que han fracasado por parte de las partes interesadas;

• la política organizacional y los objetivos e intereses ayudan a definir la política de riesgos de la organización; y

• Los objetivos y criterios específicos de un proyecto o actividad deben considerarse teniendo en cuenta los objetivos de la organización en su conjunto.

3.2.4 Establecer el contexto de la gestión de riesgos

Deben establecerse las metas, objetivos, estrategias, alcance y parámetros de la actividad o parte de la organización a la que se aplica el proceso de gestión de riesgos. El proceso debe llevarse a cabo teniendo plenamente en cuenta la necesidad de equilibrar costos, beneficios y oportunidades. También deben

especificarse los recursos necesarios y los registros que deben conservarse.

Establecer el alcance y los límites de una aplicación de la gestión de riesgos implica:

• definir la organización, proceso, proyecto o actividad y establecer sus metas y objetivos;

• especificando la naturaleza de las decisiones que deben tomarse;

• definir el alcance de la actividad o función del proyecto en términos de tiempo y ubicación;

• identificar cualquier estudio de alcance o encuadre necesario y su alcance, objetivos y los recursos requeridos; y

• definir la profundidad y amplitud de las actividades de gestión de riesgos a realizar, incluidas las inclusiones y exclusiones específicas. Los temas específicos que también pueden ser discutidos incluyen los siguientes:

• Las funciones y responsabilidades de varias partes de la organización que participan en el proceso de gestión de riesgos.

• Relaciones entre el proyecto o la actividad y otros proyectos o partes de la organización.

3.2.5 Elaborar criterios de riesgo

Decidir los criterios contra los cuales se debe evaluar el riesgo. Las decisiones sobre si se requiere tratamiento de riesgo pueden basarse en criterios operativos, técnicos, financieros, legales, sociales, ambientales, humanitarios u otros. Los criterios deben reflejar el contexto definido anteriormente. Estos dependen a menudo de las políticas internas de una organización, metas y objetivos y los intereses de las partes interesadas. Los criterios pueden verse afectados por las percepciones de las partes interesadas y por los requisitos legales o reglamentarios. Es importante que se determinen al principio los criterios apropiados.

Aunque los criterios amplios para la toma de decisiones se desarrollan inicialmente como parte del establecimiento del contexto de gestión de riesgos, pueden ser desarrollados y refinados posteriormente a medida que se identifican riesgos particulares y se eligen técnicas de análisis de riesgo. Los criterios de riesgo deben corresponder al tipo de riesgos ya la forma en que se expresan los niveles de riesgo.

3.2.6 Definir la estructura para el resto del proceso

Esto implica subdividir la actividad, el proceso, el proyecto o el cambio en un conjunto de elementos o pasos para proporcionar un marco lógico que ayude a asegurar que los riesgos significativos no se pasen por alto. La estructura elegida depende de la naturaleza de los riesgos y del alcance del proyecto, proceso o actividad.

3.3 Identificar los riesgos

3.3.1 Generalidades

Este paso busca identificar los riesgos a gestionar. La identificación completa mediante un proceso sistemático bien estructurado es crítica, ya que un riesgo no identificado en esta etapa puede ser excluido del análisis posterior. La identificación debe incluir los riesgos, estén o no bajo el control de la organización.

3.3.2 ¿Qué puede suceder, dónde y cuándo?

El objetivo es generar una lista exhaustiva de fuentes de riesgos y eventos que puedan tener un impacto en el logro de cada uno de los objetivos identificados en el contexto. Estos eventos podrían prevenir, degradar, retrasar o mejorar el logro de esos objetivos. A continuación, se consideran con más detalle para identificar lo que puede suceder.

3.3.3 ¿Por qué y cómo puede suceder?

Una vez identificado lo que podría suceder, es necesario considerar posibles causas y escenarios. Hay muchas maneras en que un evento puede ocurrir. Es importante que no se omitan causas significativas.

3.3.4 Herramientas y técnicas

Los enfoques utilizados para identificar riesgos incluyen listas de verificación, juicios basados en experiencia y registros, diagramas de flujo, brainstorming, análisis de sistemas, análisis de escenarios y técnicas de ingeniería de sistemas. Estas herramientas y técnicas se analizan con más detalle en la HB 436. El enfoque utilizado dependerá de la naturaleza de las actividades bajo revisión, los tipos de riesgo, el contexto organizacional y el propósito del estudio de gestión de riesgos.

3.4 Analizar los riesgos

3.4.1 Generalidades

El análisis de riesgo consiste en desarrollar una comprensión del riesgo. Proporciona un aporte a las decisiones sobre si los riesgos deben ser tratados y las estrategias de tratamiento de riesgo más apropiadas y

rentables. El análisis de riesgo implica la consideración del Licenciado al Profesor Barry Hart el 14 de junio de 2006. 1 usuario solo licencia de usuario personal. Se prohíbe el almacenamiento, la distribución o el uso en la red. Las fuentes de riesgo, sus consecuencias positivas y negativas y la probabilidad de que se produzcan esas consecuencias. Se pueden identificar los factores que afectan las consecuencias y la probabilidad. El riesgo se analiza combinando las consecuencias y su probabilidad. En la mayoría de los casos se tienen en cuenta los controles existentes.

Se puede llevar a cabo un análisis preliminar para que se combinen riesgos similares o se excluyan los riesgos de bajo impacto de un estudio detallado. Los riesgos excluidos deberían, en la medida de lo posible, enumerarse para demostrar la exhaustividad del análisis de riesgos.

3.4.2 Evaluar los controles existentes

Identificar los procesos, dispositivos o prácticas existentes que actúan para minimizar los riesgos negativos o mejorar los riesgos positivos y evaluar sus fortalezas y debilidades. Los controles pueden surgir como resultados de actividades de tratamiento de riesgo anteriores.

3.4.3 Consecuencias y probabilidad

La magnitud de las consecuencias de un evento, si ocurre, y la probabilidad del evento y sus consecuencias asociadas, se evalúan en el contexto de la efectividad de las estrategias y controles existentes. Un evento puede tener múltiples consecuencias y afectar a diferentes objetivos. Consecuencias y probabilidad se combinan para producir un nivel de riesgo. Las consecuencias y la probabilidad se pueden estimar utilizando análisis y cálculos estadísticos. Cuando no se dispone de datos fiables o relevantes, se pueden hacer estimaciones subjetivas que reflejen el grado de creencia de un individuo o grupo de que ocurrirá un evento o resultado particular.

Las fuentes y técnicas de información más pertinentes deben ser utilizadas al analizar las consecuencias y la probabilidad. Las fuentes de información pueden incluir lo siguiente:

- Registros pasados.
- Práctica y experiencia relevante.
- Literatura publicada relevante.
- Investigación de mercado.

• Los resultados de la consulta pública.

• Experimentos y prototipos.

• Modelos económicos, de ingeniería u otros.

• Juicios especializados y de expertos. Las técnicas incluyen:

• entrevistas estructuradas con expertos en el área de interés;

• utilización de grupos multidisciplinarios de expertos;

• evaluaciones individuales mediante cuestionarios; y

• uso de modelos y simulaciones. Cuando proceda, debe incluirse la confianza depositada en las estimaciones de los niveles de riesgo.

Licenciado al Profesor Barry Hart el 14 Jun 2006. 1 user user user licence only. Se prohíbe el almacenamiento, la distribución o el uso en la red. Las suposiciones hechas en el análisis deben ser claramente indicadas.

3.4.4 Tipos de análisis

El análisis de riesgos puede realizarse con distintos grados de detalle dependiendo del riesgo, el propósito del análisis, la información, los datos y los recursos disponibles. El análisis puede ser cualitativo, semi-cuantitativo o cuantitativo o una combinación de éstos, dependiendo de las circunstancias. El orden de complejidad y los costos de estos análisis, en orden ascendente, es cualitativo, semicuantitativo y cuantitativo. En la práctica, el análisis cualitativo suele utilizarse primero para obtener una indicación general del nivel de riesgo y para revelar los principales problemas de riesgo. Posteriormente puede ser necesario realizar análisis más específicos o cuantitativos sobre las principales cuestiones de riesgo.

La forma de análisis debe ser consistente con los criterios de evaluación de riesgo desarrollados como parte del establecimiento del contexto (ver Cláusula 3.2).

En detalle, los tipos de análisis son:

(a) Análisis cualitativo El análisis cualitativo utiliza palabras para describir la magnitud de las consecuencias potenciales y la probabilidad de que se produzcan esas consecuencias. Estas escalas se pueden adaptar o ajustar para adaptarse a las circunstancias, y diferentes descripciones pueden utilizarse para diferentes riesgos.

El análisis cualitativo puede ser utilizado:

• como actividad de selección inicial para identificar los riesgos que requieren un análisis más detallado;

• cuando este tipo de análisis es apropiado para las decisiones; o

• donde los datos numéricos o los recursos son inadecuados para un análisis cuantitativo. El análisis cualitativo debe estar fundamentado en información factual y datos cuando estén disponibles.

(b) Análisis semi-cuantitativo

En el análisis semi-cuantitativo, las escalas cualitativas tales como las descritas arriba se dan los valores. El objetivo es producir una escala de clasificación más ampliada que la que generalmente se logra en el análisis cualitativo, no sugerir valores realistas de riesgo como se intenta en el análisis cuantitativo. Sin embargo, dado que el valor asignado a cada descripción puede no tener una relación exacta con la magnitud real de las consecuencias o probabilidad, los números sólo deben combinarse utilizando una fórmula que reconozca las limitaciones de los tipos de escalas utilizadas.

Se debe tener cuidado con el uso del análisis semicuantitativo porque los números elegidos pueden no reflejar adecuadamente las relatividades y esto puede conducir a resultados inconsistentes, anómalos o inapropiados. El análisis semi-cuantitativo puede no diferenciar adecuadamente entre los riesgos, particularmente cuando las consecuencias o la probabilidad son Licencia al Profesor Barry Hart el 14 de junio de 2006. 1 user user user license only. Se prohíbe el almacenamiento, la distribución o el uso en la red. extremo.

(c) Análisis cuantitativo El análisis cuantitativo utiliza valores numéricos (en lugar de las escalas descriptivas utilizadas en el análisis cualitativo y semicuantitativo) tanto para las consecuencias como para la probabilidad, utilizando datos de diversas fuentes (como las mencionadas en la cláusula 3.4.3). La calidad del análisis depende de la precisión e integridad de los valores numéricos y la validez de los modelos utilizados.

Las consecuencias pueden ser determinadas modelando los resultados de un evento o conjunto de eventos, o por extrapolación de estudios experimentales o datos pasados. Las consecuencias pueden expresarse en

términos de criterios monetarios, técnicos o de impacto humano, o de cualquiera de los demás criterios mencionados en la cláusula 3.2.5. En algunos casos, se requiere más de un valor numérico para especificar las consecuencias para diferentes tiempos, lugares, grupos o situaciones.

La forma en que se expresan las consecuencias y la probabilidad y la forma en que se combinan para proporcionar un nivel de riesgo variará de acuerdo con el tipo de riesgo y el propósito para el cual se utilizará la evaluación de riesgos.

La incertidumbre y la variabilidad de las consecuencias y la probabilidad deben ser consideradas en el análisis y comunicadas efectivamente.

3.4.5 Análisis de sensibilidad

Dado que algunas de las estimaciones realizadas en el análisis de riesgos son imprecisas, se debe realizar un análisis de sensibilidad para probar el efecto de la incertidumbre en los supuestos y datos. El análisis de sensibilidad también es una forma de probar la idoneidad y eficacia de los controles potenciales y opciones de tratamiento de riesgo como se describe en la Cláusula 3.6.2.

3.5 Evaluar los riesgos

El propósito de la evaluación de riesgos es tomar decisiones, basadas en los resultados del análisis de riesgo, sobre los riesgos que necesitan tratamiento y prioridades de tratamiento.

La evaluación del riesgo implica comparar el nivel de riesgo encontrado durante el proceso de análisis con los criterios de riesgo establecidos cuando se consideró el contexto.

Deben considerarse los objetivos de la organización y el alcance de las oportunidades que podrían resultar. Cuando se debe elegir entre opciones, las pérdidas potenciales más altas pueden estar asociadas con mayores ganancias potenciales y la elección apropiada dependerá del contexto de la organización.

Las decisiones deben tener en cuenta el contexto más amplio del riesgo e incluir la consideración de la tolerabilidad de los riesgos soportados por las partes distintas de la organización que se beneficia de ella.

3.6 Tratar los riesgos

3.6.1 Generalidades

El tratamiento del riesgo consiste en identificar la gama de opciones para tratar los riesgos, evaluar estas

opciones y la preparación e implementación de los planes de tratamiento.

3.6.2 Identificación de opciones para el tratamiento de riesgos con resultados positivos

Las opciones de tratamiento para los riesgos que tienen resultados positivos (oportunidades) que no son necesariamente mutuamente excluyentes o apropiados en todas las circunstancias incluyen:

• Buscar activamente una oportunidad al decidir iniciar o continuar con una actividad que pueda crearla o mantenerla (cuando esto sea posible). La búsqueda inapropiada de oportunidades sin tener en cuenta los posibles resultados negativos puede comprometer otras oportunidades, así como resultar en pérdidas innecesarias.

• Cambiar la probabilidad de la oportunidad, para aumentar la probabilidad de resultados beneficiosos. • Cambiar las consecuencias, para aumentar el alcance de las ganancias.

• Compartir la oportunidad.

Esto involucra a otra parte o partes que soportan o comparten parte de los resultados positivos del riesgo, usualmente proporcionando capacidades adicionales o recursos que aumentan la probabilidad de que surja la oportunidad o el alcance de las ganancias si lo hace. Los mecanismos incluyen el uso de contratos y estructuras organizacionales tales como asociaciones, joint ventures, royalties y acuerdos de finca. Compartir los resultados positivos generalmente implica compartir algunos de los costos involucrados en su adquisición.

Los arreglos de intercambio a menudo introducen nuevos riesgos, ya que la otra parte o partes pueden no entregar las capacidades o recursos deseados de manera efectiva.

• Retener la oportunidad residual.

Una vez que las oportunidades han sido cambiadas o compartidas, puede haber oportunidades residuales que se conservan sin que se requiera acción inmediata específica.

3.6.3 Identificar opciones para tratar los riesgos con resultados negativos

Las opciones de tratamiento para los riesgos que tienen resultados negativos son similares en concepto a las de tratamiento de los riesgos con resultados positivos, aunque la interpretación y las implicaciones son claramente diferentes. Las opciones incluyen:

• Evitar el riesgo al decidir no iniciar o continuar con la actividad que da lugar al riesgo (cuando esto sea posible).

La evitación del riesgo puede ocurrir inapropiadamente si los individuos u organizaciones son innecesariamente aversos al riesgo. La evasión inadecuada del riesgo puede aumentar la importancia de otros riesgos o puede conducir a la pérdida de oportunidades de ganancia.

• Cambiar la probabilidad del riesgo, para reducir la probabilidad de los resultados negativos.

• Cambiar las consecuencias, para reducir el alcance de las pérdidas. Esto incluye medidas previas al evento tales como reducción de inventario o dispositivos de protección y respuestas posteriores al evento tales como planes de continuidad.

• Compartir el riesgo.

Esto involucra a otra parte o partes que soportan o comparten parte del riesgo, preferiblemente de mutuo consentimiento. Los mecanismos incluyen el uso de contratos, arreglos de seguros y estructuras organizacionales tales como asociaciones y joint ventures para difundir responsabilidad y responsabilidad. Generalmente hay algún costo financiero o beneficio asociado con compartir parte del riesgo con otra organización, como la prima pagada por el seguro.

Cuando los riesgos se comparten total o parcialmente, la organización que transfiere el riesgo ha adquirido un nuevo riesgo, ya que la organización a la que se ha transferido el riesgo puede no gestionar el riesgo de manera eficaz.

• Retención del riesgo.

Después de que los riesgos han sido cambiados o compartidos, habrá riesgos residuales que se conservan. Los riesgos también pueden mantenerse por defecto, p. Cuando no se identifique o se comparta apropiadamente o se trate de otro modo los riesgos.

3.6.4 Evaluación de las opciones de tratamiento del riesgo

La selección de la opción más adecuada consiste en equilibrar los costos de implementación de cada opción con los beneficios derivados de la misma. En general, el costo de la gestión de riesgos debe ser proporcional a los beneficios obtenidos. Al hacer tales juicios de costo versus beneficio se debe tener en cuenta el contexto. Es importante considerar todos los costos e ingresos

directos e indirectos tangibles o intangibles y medidos en términos financieros o de otro tipo.

Una serie de opciones pueden ser consideradas y aplicadas individualmente o en combinación. El análisis de sensibilidad (ver Cláusula 3.4.5) es una forma de probar la efectividad de diferentes opciones para el tratamiento del riesgo. La organización puede beneficiarse mediante la adopción de una combinación de opciones. Un ejemplo es el uso efectivo de contratos y tratamientos específicos de riesgo apoyados por seguros apropiados y otros financiamientos de riesgo.

Las decisiones deben tener en cuenta la necesidad de considerar cuidadosamente los riesgos raros pero graves que pueden justificar acciones de tratamiento de riesgo que no son justificables por razones estrictamente económicas. Los requisitos legales y de responsabilidad social pueden anular el simple análisis de costo-beneficio financiero.

Las opciones de tratamiento de riesgos deben considerar los valores y percepciones de las partes interesadas y las formas más apropiadas de comunicarse con ellas.

Si el presupuesto para el tratamiento del riesgo está restringido, el plan de tratamiento debe identificar claramente el orden de prioridad en el que deben aplicarse los tratamientos de riesgo individuales. Es importante comparar el costo total de no tomar medidas contra el ahorro presupuestario.

El tratamiento de riesgos puede introducir nuevos riesgos que deben ser identificados, evaluados, tratados y monitoreados.

Si, después del tratamiento, existe un riesgo residual, debe tomarse una decisión sobre si conservar este riesgo o repetir el proceso de tratamiento del riesgo.

3.6.5 Preparación e implementación de planes de tratamiento

El propósito de los planes de tratamiento es documentar cómo se implementarán las opciones elegidas. Los planes de tratamiento deben incluir:

- acciones propuestas;
- requerimientos de recursos;
- responsabilidades; • sincronización;
- medidas de desempeño; y
- Requisitos de información y seguimiento.

Los planes de tratamiento deben integrarse con los procesos administrativos y presupuestarios de la organización.

3.7 Monitorear y revisar

La revisión continua es esencial para asegurar que el plan de manejo siga siendo relevante. Los factores que pueden afectar la probabilidad y las consecuencias de un resultado pueden cambiar, al igual que los factores que afectan la idoneidad o el costo de las opciones de tratamiento. Por lo tanto, es necesario repetir el ciclo de gestión de riesgos con regularidad.

El progreso real en comparación con los planes de tratamiento de riesgos proporciona una importante medida de desempeño y debe incorporarse al sistema de gestión del desempeño, medición y reporte de la organización.

El monitoreo y la revisión también involucran el aprendizaje de las lecciones del proceso de administración de riesgos, revisando los eventos, los planes de tratamiento y sus resultados.

3.8 Registrar el proceso de gestión de riesgos

Cada etapa del proceso de gestión de riesgos debe ser registrada apropiadamente. Los supuestos, los métodos, las fuentes de datos, los análisis, los resultados y los motivos de las decisiones deberían registrarse.

Los registros de estos procesos son un aspecto importante del buen gobierno corporativo.

Las decisiones relativas a la elaboración y captura de registros deben tener en cuenta:

• las necesidades legales y comerciales de los registros;

• el costo de crear y mantener registros; y

• los beneficios de reutilizar la información.

(Referir AS ISO 15489)

4 Establecer una gestión eficaz del riesgo

4.1 Propósito

El propósito de esta sección es describir cómo desarrollar, establecer y mantener una gestión sistemática del riesgo en una organización.

Una organización debe desarrollar una política de gestión de riesgos, planes y arreglos de apoyo. Esto permitirá que la gestión de riesgos se implemente eficazmente en toda la organización. El plan debe abordar estrategias para incorporar la gestión del riesgo en los sistemas, procesos y prácticas de la organización.

Aunque el enfoque detallado descrito aquí está diseñado para organizaciones más grandes, todos los aspectos son relevantes en cierto grado para las entidades más pequeñas. Los mismos principios se aplican en los sectores público, no lucrativo y privado.

4.2 Evaluar las prácticas y necesidades existentes

En muchas organizaciones, las prácticas y procesos de gestión existentes incluyen elementos de gestión del riesgo. Algunas organizaciones pueden haber adoptado procesos de gestión de riesgos para categorías particulares de riesgo.

Antes de comenzar a desarrollar un plan de gestión de riesgos, la organización debe revisar y evaluar críticamente los elementos del proceso de gestión de riesgos que ya están en vigor. Esta revisión debe reflejar las necesidades de gestión de riesgos de la organización y su contexto.

La revisión debe ofrecer una apreciación estructurada de:

• la madurez, las características y la eficacia de la cultura y los sistemas existentes de gestión empresarial y de gestión de riesgos;

• el grado de integración y coherencia de la gestión del riesgo en toda la organización y entre los diferentes tipos de riesgos;

• los procesos y sistemas que deben ser modificados o ampliados;

• limitaciones que podrían limitar la introducción de una gestión sistemática de los riesgos;

• requisitos legislativos o de cumplimiento; y

• limitaciones de recursos.

4.3 Planificación de la gestión de riesgos

4.3.1 Elaborar planes de gestión de riesgos

El plan de gestión de riesgos debe definir cómo se llevará a cabo la gestión del riesgo en toda la organización. Los planes de tratamiento de riesgos pueden estar separados o incluirse en el plan de gestión de riesgos.

El objetivo del plan de gestión de riesgos debe ser integrar la gestión del riesgo en todas las prácticas importantes de la organización y en los procesos empresariales para que sea relevante, eficaz, eficiente y sostenido. En particular, la gestión de riesgos debe estar integrada en el desarrollo de políticas, la planificación comercial y estratégica y los procesos de gestión del cambio. También es probable que esté incorporado en otros planes y procesos como los de gestión de activos, auditoría, continuidad de negocios, gestión ambiental, control de fraude, recursos humanos, inversión y gestión de proyectos.

El plan de gestión de riesgos puede incluir secciones específicas para funciones, áreas, proyectos, actividades o procesos específicos. En la práctica, estas secciones pueden ser planes separados; Estos deben ser consistentes con la política de gestión de riesgos de la organización.

4.3.2 Garantizar el apoyo de la alta dirección

Es importante conocer y comprometerse con la gestión del riesgo en los niveles de alta dirección. Esto puede lograrse mediante:

• obtener el apoyo activo y continuo de los directores y altos ejecutivos de la organización para la gestión de riesgos y para el desarrollo e implementación de la política y el plan de gestión de riesgos;

• nombrar a un alto directivo o "campeón" (o equipo) similar para dirigir y patrocinar iniciativas; y

• obtener el compromiso y el apoyo de todos los altos directivos para la ejecución del plan de gestión de riesgos.

4.3.3 Desarrollar y comunicar la política de gestión de riesgos

El directorio o el ejecutivo de la organización debe definir y documentar su política de gestión del riesgo, incluidos los objetivos y su compromiso con la gestión de riesgos. La póliza puede incluir:

• los objetivos y la lógica de la gestión del riesgo;

• los vínculos entre la política y los planes estratégicos de la organización;

• la extensión y tipos de riesgo que la organización tomará y las formas en que equilibrará amenazas y oportunidades;

• los procesos que se utilizarán para gestionar el riesgo;

• responsabilidad por la gestión de riesgos particulares;

• detalles del apoyo y la experiencia disponibles para ayudar a los responsables de la gestión de los riesgos;
• una declaración sobre cómo se medirá y reportará el desempeño de la gestión de riesgos;

• un compromiso con la revisión periódica del sistema de gestión de riesgos; y

• una declaración de compromiso con la política de los directores y el ejecutivo de la organización.

Publicar y comunicar una declaración de política de este tipo demuestra el compromiso del ejecutivo de la organización con la gestión de riesgos. La comunicación puede incluir:

• establecer un equipo, incluidos los altos directivos, responsable de la comunicación sobre la gestión del riesgo y de la política de la organización; y

• sensibilizar sobre la gestión de riesgos y el proceso de gestión de riesgos en toda la organización.

4.3.4 Establecer responsabilidad y autoridad

Los directores y altos ejecutivos son responsables en última instancia de la gestión del riesgo en la organización. Todo el personal es responsable de gestionar los riesgos en sus áreas de control. Esto puede ser facilitado por:

• especificar los responsables de la gestión de determinados riesgos o categorías de riesgos, de la aplicación de estrategias de tratamiento y del mantenimiento de los controles de riesgos;

• establecer procesos de medición del rendimiento y de presentación de informes; y

• asegurar niveles apropiados de reconocimiento, recompensa, aprobación y sanción.

4.3.5 Personalizar el proceso de gestión de riesgos

El proceso de gestión de riesgos debe ser personalizado para la organización, sus políticas, procedimientos y cultura teniendo en cuenta el proceso de revisión descrito en la Cláusula 4.2.

4.3.6 Asegurar recursos adecuados

La organización debe identificar los recursos necesarios para la gestión de riesgos. Esto debe incluir la consideración de:

• personas y habilidades;

• procesos y procedimientos documentados;

• sistemas de información y bases de datos; y

• dinero y otros recursos para actividades específicas de tratamiento de riesgos.

El plan de gestión de riesgos debe especificar cómo se desarrollarán y mantendrán las habilidades de gestión de riesgos de los gerentes y el personal.

Los sistemas de información de gestión de riesgos pueden tener la capacidad de:

• registrar detalles de riesgos, controles y prioridades y mostrar cualquier cambio en ellos;

• registrar tratamientos de riesgo y requerimientos de recursos asociados;

• registrar detalles de incidentes y eventos de pérdidas y las lecciones aprendidas;

• rastrear la responsabilidad por los riesgos, los controles y los tratamientos;

• seguir el progreso y registrar la finalización de las acciones de tratamiento de riesgos;

• permitir medir el progreso con respecto al plan de gestión de riesgos; y

• activar la actividad de supervisión y aseguramiento.